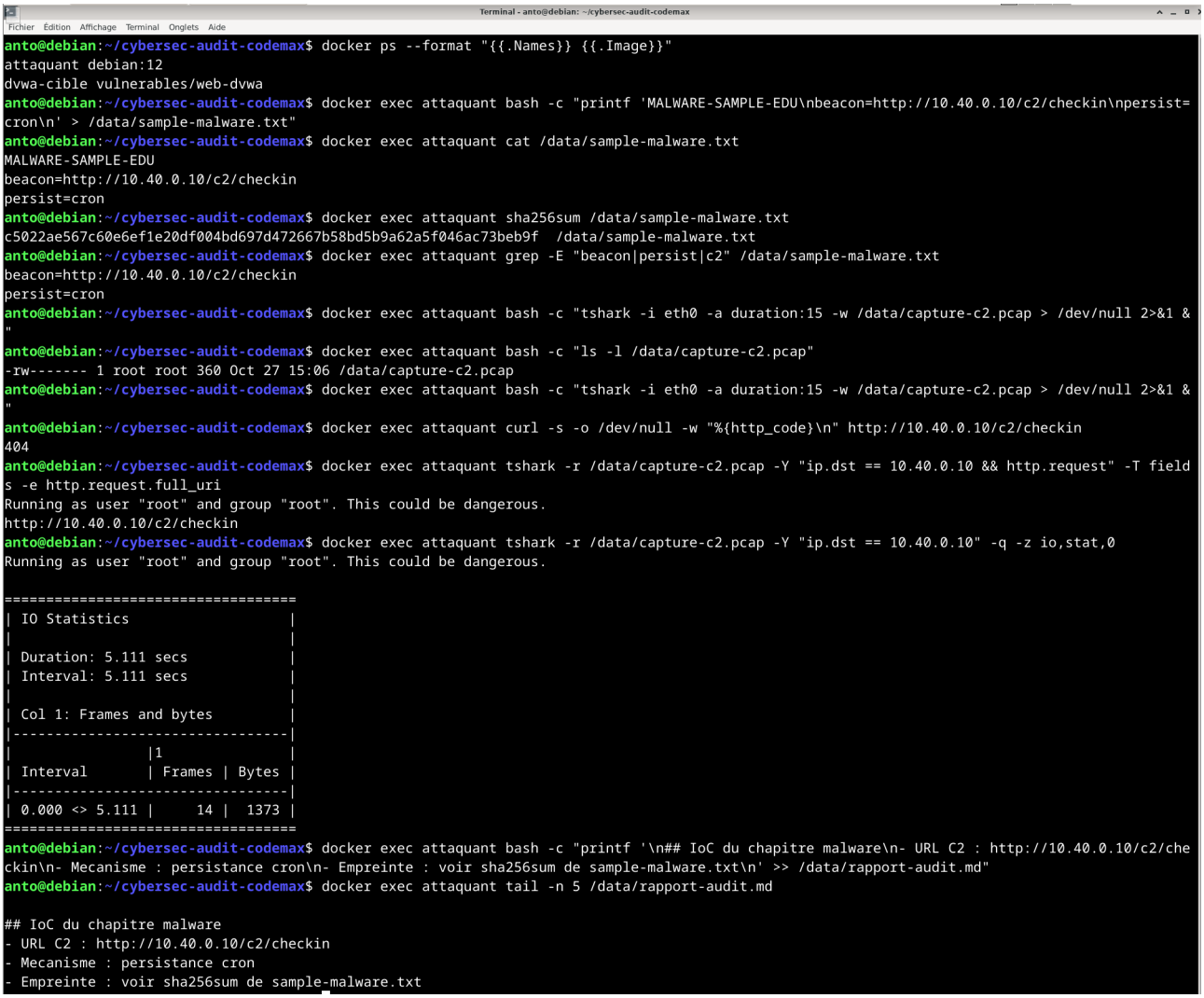
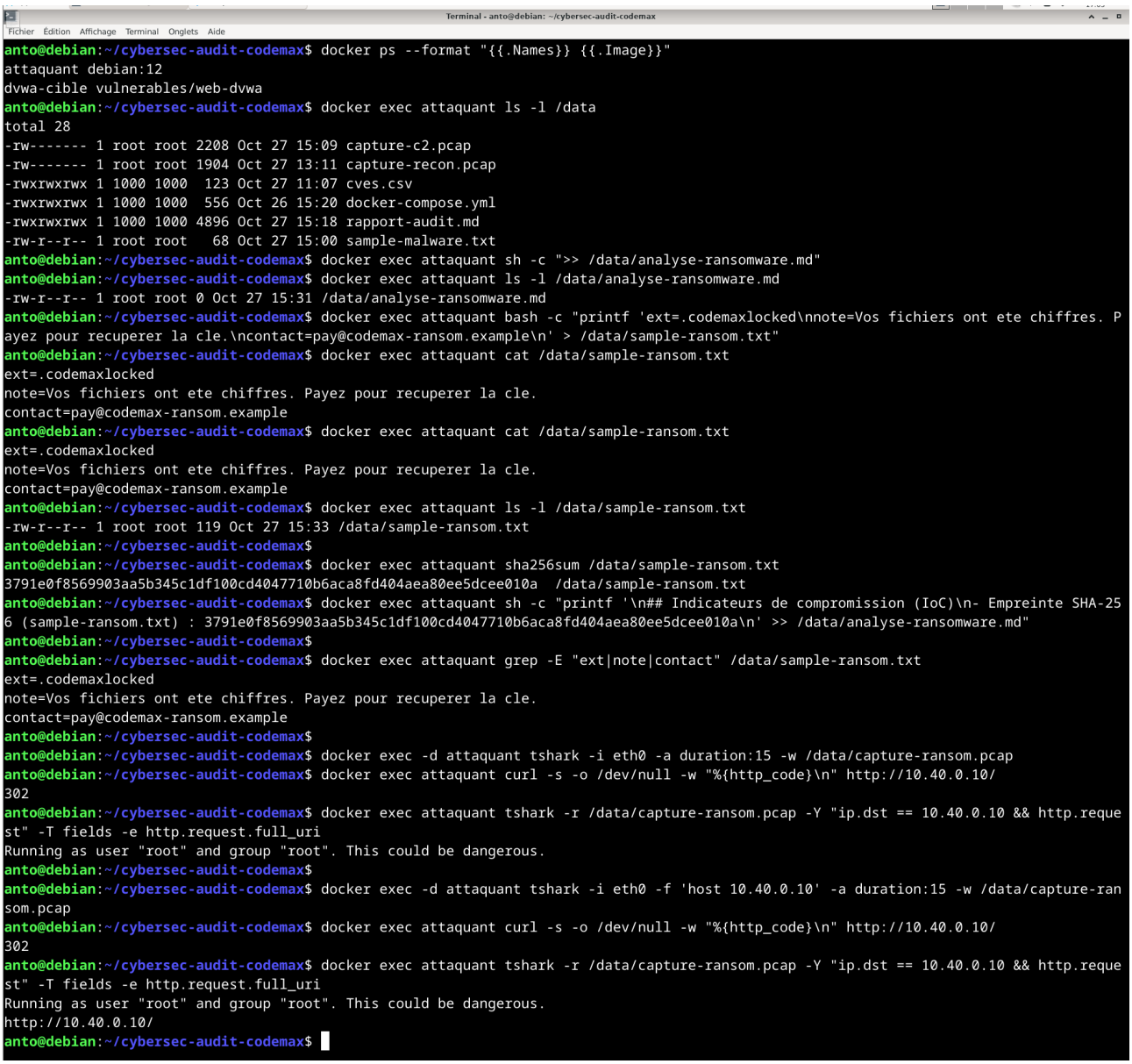
CAPTURES Exercice 04 — Analyser une chaîne d'infection simuléede ransomware et documenter ses indicateurs

Exemple 04



Exercice 04


Terminal - anto@debian: ~/cybersec-audit-codemax
Fichier Édition Affichage Terminal Onglets Aide
anto@debian:~/cybersec-audit-codemax$ docker ps --format "{{.Names}} {{.Image}}"
attaquant debian:12
dvwa-cible vulnerables/web-dvwa
anto@debian:~/cybersec-audit-codemax$ docker exec attaquant ls -l /data
total 28
-rw------- 1 root root 2208 Oct 27 15:09 capture-c2.pcap
-rw------- 1 root root 1904 Oct 27 13:11 capture-recon.pcap
-rwxrwxrwx 1 1000 1000 123 Oct 27 11:07 cves.csv
-rwxrwxrwx 1 1000 1000 556 Oct 26 15:20 docker-compose.yml
-rwxrwxrwx 1 1000 1000 4896 Oct 27 15:18 rapport-audit.md
-rw-r--r-- 1 root root   68 Oct 27 15:00 sample-malware.txt
anto@debian:~/cybersec-audit-codemax$ docker exec attaquant sh -c ">> /data/analyse-ransomware.md"
anto@debian:~/cybersec-audit-codemax$ docker exec attaquant ls -l /data/analyse-ransomware.md
-rw-r--r-- 1 root root 0 Oct 27 15:31 /data/analyse-ransomware.md
anto@debian:~/cybersec-audit-codemax$ docker exec attaquant bash -c "printf 'ext=.codemaxlocked\nnote=Vos fichiers ont ete chiffres. P
ayez pour recuperer la cle.\ncontact=pay@codemax-ransom.example\n' > /data/sample-ransom.txt"
anto@debian:~/cybersec-audit-codemax$ docker exec attaquant cat /data/sample-ransom.txt
ext=.codemaxlocked
note=Vos fichiers ont ete chiffres. Payez pour recuperer la cle.
contact=pay@codemax-ransom.example
anto@debian:~/cybersec-audit-codemax$ docker exec attaquant cat /data/sample-ransom.txt
ext=.codemaxlocked
note=Vos fichiers ont ete chiffres. Payez pour recuperer la cle.
contact=pay@codemax-ransom.example
anto@debian:~/cybersec-audit-codemax$ docker exec attaquant ls -l /data/sample-ransom.txt
-rw-r--r-- 1 root root 119 Oct 27 15:33 /data/sample-ransom.txt
anto@debian:~/cybersec-audit-codemax$
anto@debian:~/cybersec-audit-codemax$ docker exec attaquant sha256sum /data/sample-ransom.txt
3791e0f8569903aa5b345c1df100cd4047710b6aca8fd404aea80ee5dcee010a /data/sample-ransom.txt
anto@debian:~/cybersec-audit-codemax$ docker exec attaquant sh -c "printf '\n## Indicateurs de compromission (IoC)\n- Empreinte SHA-25
6 (sample-ransom.txt) : 3791e0f8569903aa5b345c1df100cd4047710b6aca8fd404aea80ee5dcee010a\n' >> /data/analyse-ransomware.md"
anto@debian:~/cybersec-audit-codemax$
anto@debian:~/cybersec-audit-codemax$ docker exec attaquant grep -E "ext|note|contact" /data/sample-ransom.txt
ext=.codemaxlocked
note=Vos fichiers ont ete chiffres. Payez pour recuperer la cle.
contact=pay@codemax-ransom.example
anto@debian:~/cybersec-audit-codemax$
anto@debian:~/cybersec-audit-codemax$ docker exec -d attaquant tshark -i eth0 -a duration:15 -w /data/capture-ransom.pcap
anto@debian:~/cybersec-audit-codemax$ docker exec attaquant curl -s -o /dev/null -w "%{http_code}\n" http://10.40.0.10/
302
anto@debian:~/cybersec-audit-codemax$ docker exec attaquant tshark -r /data/capture-ransom.pcap -Y "ip.dst == 10.40.0.10 && http.reque
st" -T fields -e http.request.full_uri
Running as user "root" and group "root". This could be dangerous.
anto@debian:~/cybersec-audit-codemax$
anto@debian:~/cybersec-audit-codemax$ docker exec -d attaquant tshark -i eth0 -f 'host 10.40.0.10' -a duration:15 -w /data/capture-ran
som.pcap
anto@debian:~/cybersec-audit-codemax$ docker exec attaquant curl -s -o /dev/null -w "%{http_code}\n" http://10.40.0.10/
302
anto@debian:~/cybersec-audit-codemax$ docker exec attaquant tshark -r /data/capture-ransom.pcap -Y "ip.dst == 10.40.0.10 && http.reque
st" -T fields -e http.request.full_uri
Running as user "root" and group "root". This could be dangerous.
http://10.40.0.10/
anto@debian:~/cybersec-audit-codemax$

```
anto@debian:~/cybersec-audit-codemax$ docker exec attaquant tail -n 20 /data/analyse-ransomware.md
| **Ransomware** | Chiffre les données et extorse une rançon (double extorsion : vol + chiffrement) | Emai
l piégé, accès initial (RDP/VPN) puis mouvement latéral | Extension inconnue + note de rançon + modificati
ons massives de fichiers |
| **Botnet** | Pilote des machines zombies via un serveur Command & Control | Machine compromise enrôlée (
via un des vecteurs ci-dessus) | Trafic périodique (beacon) vers l'URL/IP du serveur C&C |

Lecture du tableau : tout malware est un **payload + un mode de propagation**, et
on le détecte soit par **signature connue**, soit par **IoC observable** (les
deux approches utilisées dans cette fiche).

## 6. Conclusion

La chaîne d'infection d'un ransomware a été reconstituée sans aucun risque :
vecteur simulé (pièce jointe), empreinte SHA-256 relevée et consignée, motifs
caractéristiques extraits par analyse statique, trafic de commande et contrôle
capturé et prouvé dans `capture-ransom.pcap`. La fiche d'IoC est directement
exploitable par une équipe de réponse (recherche de l'empreinte, blocage de
l'adresse et de l'URL, isolement).

**Livrables de l'exercice :** `analyse-ransomware.md` (cette fiche),
`sample-ransom.txt` (échantillon inoffensif), `capture-ransom.pcap` (preuve
réseau). Le constat peut être ajouté au registre du fil rouge :
`OBS-002;faux ransomware simulé;pedagogique;Analyste SOC;ferme`.anto@debian:~/cybersec-audit-codemax$
```